

# **Azure Cloud Governance, Risk, and Compliance (GRC) Assessment for a Small Law Firm**

## **1. Executive Summary**

The purpose of this project is to demonstrate how cybersecurity Governance, Risk, and Compliance (GRC) practices can be implemented within a cloud environment using Microsoft Azure.

The project simulates a law firm cloud infrastructure where sensitive legal documents and client information must be protected. The environment was designed using Azure cloud services and security best practices, including identity governance, network segmentation, secure storage, and policy enforcement.

Following the technical deployment, the environment was evaluated through a GRC lens by identifying potential security risks and mapping implemented controls to industry compliance frameworks including NIST SP 800-53, ISO 27001, SOC 2, PCI DSS, and PIPEDA.

This project demonstrates how organizations can implement cloud governance and security controls to protect sensitive data while maintaining regulatory compliance.

## **2. Problem Statement**

Organizations increasingly rely on cloud computing platforms to host applications and store sensitive data. However, poorly governed cloud environments can introduce security risks such as unauthorized access, insecure configurations, and data exposure.

For organizations such as law firms that handle confidential client information, these risks can lead to data breaches, regulatory violations, and loss of client trust.

Common cloud security challenges include:

- Lack of resource ownership and accountability
- Misconfigured network security controls
- Unrestricted public access to storage resources
- Weak identity and access management
- Non-compliance with data protection regulations

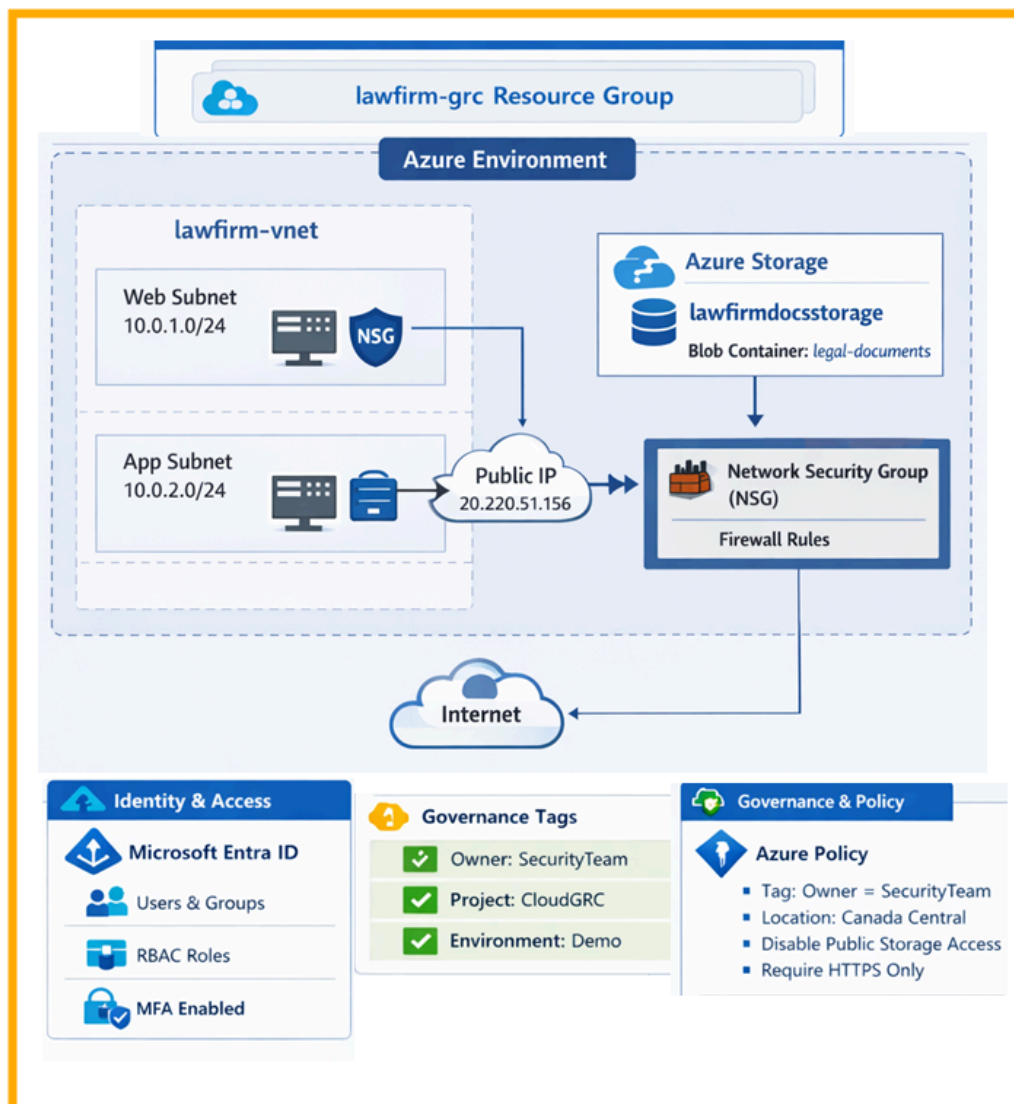
This project addresses these challenges by designing a secure Azure cloud environment that incorporates governance policies, identity security controls, network segmentation, and secure storage practices.

### 3. Project Objectives

The main objectives of this project are:

- Design a secure Azure cloud environment using cybersecurity best practices
- Implement governance controls using resource groups and tagging
- Configure identity and access management using Microsoft Entra ID and RBAC
- Implement network segmentation and firewall controls
- Secure sensitive data using encrypted Azure Blob Storage
- Enforce governance rules using Azure Policy
- Perform a compliance and risk assessment of the deployed environment

### 4. Azure Cloud Architecture



## Architecture Overview

The architecture was designed to simulate a secure cloud environment for a law firm handling sensitive legal documents.

The environment is organized around a dedicated Azure Resource Group called **lawfirm-grc**, which serves as the governance boundary for all deployed resources.

Within this environment, several layers of security controls were implemented, including identity management, network segmentation, secure application hosting, and encrypted data storage.

## 5. Governance Foundation

The project begins with the creation of a dedicated Azure Resource Group that acts as the central governance boundary.

Resource groups allow organizations to organize cloud resources and apply governance controls such as RBAC permissions, policy enforcement, and compliance monitoring.

To support asset governance and accountability, resource tags were applied during deployment.

### Governance Tags

Owner – SecurityTeam

Project – CloudGRC

Environment – Demo

These tags allow organizations to track resource ownership, enforce governance policies, and maintain visibility into deployed assets.

Microsoft Azure

Search resources, services, and docs (G+)

Copilot

Home > Resource Manager | Resource groups

Create a resource group ...

BasicsTagsReview + create

[Automation Link](#)

**Basics**

Subscription

Azure subscription 1

Resource group name

lawfirm-grc

Region

Canada Central

**Tags**

Owner

SecurityTeam

Project

CloudGRC

Environment

Demo

Previous

Next

Create

Compliance Mapping:

| Framework      | Control                                       | Description                                                                                                                                                       |
|----------------|-----------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NIST SP 800-53 | CM-8 – Information System Component Inventory | Requires organizations to maintain an inventory of system components. The Azure Resource Group and governance tags help identify and track deployed cloud assets. |
| ISO/IEC 27001  | A.8 – Asset Management                        | Organizations must identify and manage information system assets. Resource grouping and tagging support asset identification and ownership tracking.              |
| SOC 2          | CC1 – Control Environment                     | Establishes governance structures and accountability for systems. Governance tags define resource ownership and project responsibility.                           |

|                |                                             |                                                                                                                                                             |
|----------------|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>PCI DSS</b> | <b>Requirement 12 – Security Governance</b> | Requires organizations to maintain governance processes for system management. Resource grouping and tagging support security oversight and accountability. |
| <b>PIPEDA</b>  | <b>Accountability Principle</b>             | Organizations must assign responsibility for protecting personal information. Governance tags identify the responsible team managing cloud resources.       |

## 6. Identity and Access Management (IAM)

Identity governance was implemented using **Microsoft Entra ID**.

The following controls were deployed:

- User identities representing organizational roles
- Security groups to manage access permissions
- Role-Based Access Control (RBAC) assignments
- Multi-Factor Authentication (MFA)

RBAC roles were assigned to enforce the principle of **least privilege**, ensuring that users only have access to resources required for their responsibilities.

Microsoft Entra ID → Users

Home

**Users** ...  
Default Directory

⌵ ⏪ + New user ✎ Edit 🗑 Delete ⬇ Download users (Preview) 📄 Bulk operations ⌵ 🔄 Refresh ⚙ Manage view ⌵

**All users** ⓘ Azure Active Directory is now Microsoft Entra ID. 🔗

🔍 Search ⌵ Add filter

5 users found

| <input type="checkbox"/> | Display name ↑                                                                              | User principal name ↑ | User type | Is Agent | On-premises sy... |
|--------------------------|---------------------------------------------------------------------------------------------|-----------------------|-----------|----------|-------------------|
| <input type="checkbox"/> |  admin   | admin@shohagm... 📄    | Member    | No       | No                |
| <input type="checkbox"/> |  client  | client@shohagmd... 📄  | Member    | No       | No                |
| <input type="checkbox"/> |  finance | finance@shohag... 📄   | Member    | No       | No                |
| <input type="checkbox"/> |  lawyer  | lawyer@shohagm... 📄   | Member    | No       | No                |

 All users  
 Audit logs  
 Sign-in logs  
 Diagnose and solve problems  
 Deleted users  
 Password reset  
 User settings  
 Bulk operation results  
 Bulk operation results (Preview)  
 New support request

Entra ID → Groups list

Home

 **Groups** | All groups

Default Directory

New group

Download groups

Refresh

Manage view

Delete

Got feedback?

Overview

**All groups**

Insights (Preview)

Deleted groups

Diagnose and solve problems

Settings

Activity

Troubleshooting + Support

Microsoft Entra has a simpler, integrated experience for managing all your Identity and Access Management needs. Try the new Microsoft Entra admin center!

Search

Add filter

Search mode

Contains

4 groups found

| <input type="checkbox"/> | Name ↑                                                                                        | Object Id                            | Group type | Membership type |
|--------------------------|-----------------------------------------------------------------------------------------------|--------------------------------------|------------|-----------------|
| <input type="checkbox"/> |  Clients     | a5e56f7a-9284-4ea8-bb4d-5d9d8be495f0 | Security   | Assigned        |
| <input type="checkbox"/> |  CloudAdmins | 96480e76-eec9-4123-bce4-064539fee7d  | Security   | Assigned        |
| <input type="checkbox"/> |  FinanceTeam | ae2af637-45d7-4c3c-a239-082363be5a64 | Security   | Assigned        |
| <input type="checkbox"/> |  LegalTeam   | f02811f0-e832-4fa1-bbae-b4154fc05a91 | Security   | Assigned        |

Compliance Mapping:

| Framework      | Control                                  | Description                                                                                                                                                               |
|----------------|------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NIST SP 800-53 | AC-2 – Account Management                | Requires organizations to manage user accounts and permissions. Microsoft Entra ID users and security groups provide centralized account and identity management.         |
| NIST SP 800-53 | AC-3 – Access Enforcement                | Ensures system access is restricted based on defined authorization rules. Azure RBAC roles enforce least-privilege access to cloud resources.                             |
| NIST SP 800-53 | IA-2 – Identification and Authentication | Requires strong authentication mechanisms. Multi-Factor Authentication adds an additional verification layer for user authentication.                                     |
| ISO/IEC 27001  | A.9 – Access Control                     | Requires access to systems to be controlled based on business roles. RBAC roles and security groups ensure users receive permissions aligned with their responsibilities. |

|                |                                                             |                                                                                                                                                                       |
|----------------|-------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>SOC 2</b>   | <b>CC6 – Logical Access Controls</b>                        | Systems must restrict access to authorized users. Identity governance and RBAC ensure users can only access permitted resources.                                      |
| <b>PCI DSS</b> | <b>Requirement 7 – Restrict Access to System Components</b> | Access must be limited based on business need-to-know. RBAC roles ensure permissions are assigned based on user responsibilities.                                     |
| <b>PCI DSS</b> | <b>Requirement 8 – Identify and Authenticate Users</b>      | Requires strong authentication mechanisms including MFA for system access. MFA strengthens authentication security for privileged accounts.                           |
| <b>PIPEDA</b>  | <b>Safeguards Principle</b>                                 | Organizations must protect personal information through appropriate safeguards. Identity governance controls help prevent unauthorized access to sensitive resources. |

## 7. Network Security Architecture

Network security was implemented using an Azure Virtual Network.

Virtual Network Configuration

Virtual Network: **lawfirm-vnet**

Address Space: **10.0.0.0/16**

Two subnets were created to simulate application layer separation:

Web Subnet – 10.0.1.0/24

App Subnet – 10.0.2.0/24

Network segmentation reduces the risk of unauthorized lateral movement between systems and supports a defense-in-depth security strategy.

Home > Create a resource > Marketplace

Create virtual network <div>...</div>

<div>✔ Validation passed</div>

BasicsSecurityIP addressesTagsReview + create

View automation template

Basics

SubscriptionAzure subscription 1

Resource Grouplawfirm-grc

Namedlawfirm-vnet

RegionCanada Central

Security

Azure BastionDisabled

Azure FirewallDisabled

Azure DDoS Network ProtectionDisabled

IP addresses

Address space10.0.0.0/16 (65,536 addresses)

Subnetweb-subnet (10.0.1.0/24) (256 addresses)

Subnetapp-subnet (10.0.2.0/24) (256 addresses)

Tags

EnvironmentDemo

ProjectCloudGRC

OwnerSecurityTeam

Compliance Mapping:

| Framework      | Control                            | Description                                                                                                                                                                                               |
|----------------|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| NIST SP 800-53 | SC-7 – Boundary Protection         | Requires organizations to monitor and control communications at system boundaries. The Azure Virtual Network and subnet segmentation establish logical network boundaries between application components. |
| ISO/IEC 27001  | A.13 – Network Security Management | Requires organizations to protect information within networks and supporting infrastructure. Virtual networks and subnet                                                                                  |



|                |                                                  |                                                                                                                                                                                                |
|----------------|--------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                |                                                  | segmentation support secure network design and controlled communication paths.                                                                                                                 |
| <b>SOC 2</b>   | <b>CC6 – Logical Access Controls</b>             | Systems must implement logical controls to prevent unauthorized access. Network segmentation helps isolate workloads and control traffic between cloud resources.                              |
| <b>PCI DSS</b> | <b>Requirement 1 – Network Security Controls</b> | Requires organizations to implement network security mechanisms to protect systems and data. The Virtual Network and subnet structure demonstrate foundational network segmentation practices. |
| <b>PIPEDA</b>  | <b>Safeguards Principle</b>                      | Organizations must implement appropriate safeguards to protect personal information. Network segmentation supports the protection of systems that may process or store sensitive data.         |

## 8. Application Infrastructure

A Linux virtual machine named **lawfirm-frontend-vm-1** was deployed in the web subnet to simulate a client-facing application server.

The server hosts a lightweight **Nginx web application**, which demonstrates how cloud infrastructure can host business applications within a governed environment.

The VM is accessible via a public IP address while remaining protected by network security controls.

lawfirm-frontend-vm-1 Virtual machine

Help me copy this VM in any region Manage this VM with Azure CLI

Search Help me copy this VM in any region

Overview Activity log Access control (IAM) Tags Diagnose and solve problems Monitor Resource visualizer Connect Connect Bastion Networking Settings Availability + scale Security Backup + disaster recovery Operations Monitoring Automation Help

Essentials

Resource group (move) lawfirm-grc

Status Running

Location Canada Central (Zone 1)

Subscription (move) Azure subscription 1

Subscription ID 1fd9de6-f85e-4799-8015-a37184dac886

Availability zone 1

Operating system Linux (ubuntu 24.04)

Size Standard D2s v3 (2 vcpus, 8 GiB memory)

Primary NIC public IP 20.220.51.156 1 associated public IPs

Virtual network/subnet lawfirm-vnet/web-subnet

DNS name Not configured

Health state -

Time created 3/14/2026, 11:43 AM UTC

Tags (edit) Environment : Demo More (2)

Properties Monitoring Capabilities (7) Recommendations Tutorials

Virtual machine

Computer name lawfirm-frontend-vm-1

Operating system Linux (ubuntu 24.04)

VM generation V2

VM architecture x64

Agent status Ready

Agent version 2.15.1.3

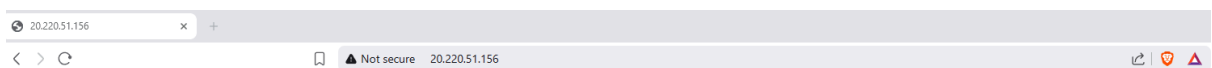
Networking

Public IP address 20.220.51.156 (Network lawfirm- ) interface frontend-vm-1406\_z1 1 associated public IPs

Public IP address (IPv6) -

Private IP address 10.0.1.4

```
azureuser@lawfirm-frontend-vm-1:~$ sudo systemctl start nginx
azureuser@lawfirm-frontend-vm-1:~$ sudo systemctl enable nginx
Synchronizing state of nginx.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable nginx
azureuser@lawfirm-frontend-vm-1:~$ echo '<html><body><h1>Law Firm Front-End App Running</h1></body></html>' | sudo tee /var/www/html/index.html
<html><body><h1>Law Firm Front-End App Running</h1></body></html>
azureuser@lawfirm-frontend-vm-1:~$
```



## Law Firm Front-End App Running

### Compliance Mapping:

| Framework             | Control                                            | Description                                                                                                                                                                      |
|-----------------------|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST SP 800-53</b> | <b>CM-7 – Least Functionality</b>                  | Systems should be configured with only necessary services enabled. The VM runs a minimal Nginx web service to reduce the attack surface.                                         |
| <b>NIST SP 800-53</b> | <b>CM-6 – Configuration Settings</b>               | Systems must follow secure configuration baselines. The virtual machine was deployed using a controlled Ubuntu image within a managed cloud environment.                         |
| <b>ISO/IEC 27001</b>  | <b>A.12 – Operations Security</b>                  | Organizations must ensure secure operation and management of information systems. The VM represents a managed application server operating within the secured Azure environment. |
| <b>ISO/IEC 27001</b>  | <b>A.13 – Network Security Management</b>          | Network infrastructure should be securely managed and controlled. The application server is deployed within a segmented subnet inside the Azure Virtual Network.                 |
| <b>SOC 2</b>          | <b>CC6 – Logical Access Controls</b>               | Systems must enforce logical controls to restrict unauthorized access. The VM operates within a governed environment protected by IAM and network security controls.             |
| <b>PCI DSS</b>        | <b>Requirement 2 – Secure System Configuration</b> | Systems must be securely configured before deployment. The Linux VM was deployed with minimal services to limit exposure to potential vulnerabilities.                           |
| <b>PIPEDA</b>         | <b>Safeguards Principle</b>                        | Organizations must implement safeguards to protect information systems. The controlled cloud infrastructure helps protect systems handling sensitive data.                       |

## 9. Network Security Controls

A **Network Security Group (NSG)** was automatically created and associated with the virtual machine network interface.

The NSG functions as a virtual firewall controlling inbound network traffic.

Inbound rules allow only necessary ports:

Port 22 – SSH access for system administration

Port 80 – HTTP access for the web application

All other inbound traffic is denied by default.

This configuration follows the **least privilege networking principle**.

**lawfirm-frontend-vm-1-nsg** Network security group

Search

Overview

- Activity log
- Access control (IAM)
- Tags
- Diagnose and solve problems
- Resource visualizer
- Settings
- Monitoring
- Automation
- Help

Essentials

Resource group (move) [lawfirm-grc](#)

Location: Canada Central

Subscription (move) [Azure subscription 1](#)

Subscription ID: 1fd9de6-f85e-4799-8015-a37184dac886

Tags (edit)

Environment: Demo Project: CloudGRC

Custom security rules: 2 inbound, 0 outbound

Associated with: 0 subnets, 2 network interfaces

Filter by name

Port == all Protocol == all Source == all Destination == all Action == all

| Priority                | Name                   | Port | Protocol | Source            | Destination |
|-------------------------|------------------------|------|----------|-------------------|-------------|
| Inbound Security Rules  |                        |      |          |                   |             |
| 300                     | SSH                    | 22   | TCP      | Any               | Any         |
| 320                     | HTTP                   | 80   | TCP      | Any               | Any         |
| 65000                   | AllowVnetInBound       | Any  | Any      | VirtualNetwork    | VirtualNetv |
| 65001                   | AllowAzureLoadBalan... | Any  | Any      | AzureLoadBalancer | Any         |
| 65500                   | DenyAllInBound         | Any  | Any      | Any               | Any         |
| Outbound Security Rules |                        |      |          |                   |             |
| 65000                   | AllowVnetOutBound      | Any  | Any      | VirtualNetwork    | VirtualNetv |
| 65001                   | AllowInternetOutBound  | Any  | Any      | Any               | Internet    |
| 65500                   | DenyAllOutBound        | Any  | Any      | Any               | Any         |

Add or remove favorites by pressing Ctrl+L+Shift+F

**Compliance Mapping:**

| <b>Framework</b>      | <b>Control</b>                                   | <b>Description</b>                                                                                                                                                               |
|-----------------------|--------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST SP 800-53</b> | <b>SC-7 – Boundary Protection</b>                | Requires organizations to monitor and control communications at system boundaries. The Network Security Group filters inbound traffic and restricts unauthorized network access. |
| <b>ISO/IEC 27001</b>  | <b>A.13 – Network Security Management</b>        | Organizations must implement network controls to protect information systems. The NSG restricts network access by allowing only approved ports.                                  |
| <b>SOC 2</b>          | <b>CC6 – Logical Access Controls</b>             | Systems must implement controls to prevent unauthorized access. Firewall rules limit inbound traffic to authorized services only.                                                |
| <b>PCI DSS</b>        | <b>Requirement 1 – Network Security Controls</b> | Organizations must implement firewall protections between networks and systems. The NSG enforces firewall rules controlling access to the virtual machine.                       |
| <b>PIPEDA</b>         | <b>Safeguards Principle</b>                      | Organizations must implement appropriate safeguards to protect information systems. Network traffic filtering helps prevent unauthorized system access.                          |

# 10. Secure Data Storage

Sensitive legal documents are stored using Azure Blob Storage.

Storage Account: **lawfirmdocsstorage**

Container: **legal-documents**

Security controls include:

- Private container access
- Encryption of data at rest
- HTTPS secure transfer enforcement
- Soft delete protection

These controls protect sensitive legal documents from unauthorized access and accidental data loss.

**lawfirmdocsstorage**  
Storage account

Search

Overview

- Activity log
- Tags
- Diagnose and solve problems
- Access Control (IAM)
- Data migration
- Events
- Storage browser
- Storage Mover
- Partner solutions
- Resource visualizer
- Data storage
  - Containers
  - File shares
  - Queues
  - Tables
- Security + networking
  - Networking
    - Front Door and CDN
    - Access keys
    - Shared access signature
    - Encryption
    - Microsoft Defender for Cloud

Upload Open in Explorer Delete Move Refresh Open in mobile CLI / PS Feedback

JSON View

Essentials

Resource group (move)  
[lawfirm-grc](#)

Location  
canadacentral

Subscription (move)  
[Azure subscription 1](#)

Subscription ID  
1fdf9de6-f85e-4799-8015-a37184dac886

Disk state  
Available

Tags (edit)

Environment : Demo Owner : SecurityTeam Show more (1)

Properties Monitoring Capabilities (7) Recommendations (0) Tutorials Tools + SDKs

**Blob service**

|                                |                  |
|--------------------------------|------------------|
| Hierarchical namespace         | Disabled         |
| Default access tier            | Hot              |
| Blob anonymous access          | Disabled         |
| Blob soft delete               | Enabled (7 days) |
| Container soft delete          | Enabled (7 days) |
| Versioning                     | Disabled         |
| Change feed                    | Disabled         |
| NFS v3                         | Disabled         |
| Allow cross-tenant replication | Disabled         |
| Storage tasks assignments      | None             |

**Security**

|                                                 |             |
|-------------------------------------------------|-------------|
| Require secure transfer for REST API operations | Enabled     |
| Storage account key access                      | Enabled     |
| Minimum TLS version                             | Version 1.2 |
| Infrastructure encryption                       | Disabled    |

**Networking**

|                              |                          |
|------------------------------|--------------------------|
| Public network access        | Enabled                  |
| Public network access scope  | Enable from all networks |
| Private endpoint connections | 0                        |
| Network routing              |                          |

Add or remove favorites by pressing Ctrl+Shift+F

**Compliance Mapping:**

| <b>Framework</b>      | <b>Control</b>                                   | <b>Description</b>                                                                                                                                      |
|-----------------------|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>NIST SP 800-53</b> | <b>SC-28 – Protection of Information at Rest</b> | Requires organizations to protect sensitive data stored in systems. Azure Storage encrypts data at rest to protect stored legal documents.              |
| <b>NIST SP 800-53</b> | <b>AC-3 – Access Enforcement</b>                 | Ensures that access to information resources is restricted to authorized users. Private container settings prevent unauthorized or anonymous access.    |
| <b>ISO/IEC 27001</b>  | <b>A.10 – Cryptographic Controls</b>             | Organizations must use cryptography to protect sensitive information. Azure Storage encryption protects legal documents stored within the environment.  |
| <b>SOC 2</b>          | <b>CC6 – Logical Access Controls</b>             | Systems must restrict access to sensitive information. Private container access ensures that stored data can only be accessed by authorized users.      |
| <b>PCI DSS</b>        | <b>Requirement 3 – Protect Stored Data</b>       | Sensitive data must be protected through encryption and access restrictions. Storage encryption protects sensitive information stored in the cloud.     |
| <b>PIPEDA</b>         | <b>Safeguards Principle</b>                      | Organizations must implement safeguards to protect personal information. Encryption and restricted storage access help protect sensitive legal records. |

# 11. Governance Policy Enforcement

To strengthen governance and prevent insecure cloud configurations, several **Azure Policy controls** were implemented across the project environment. Azure Policy provides centralized enforcement of organizational security standards and ensures that deployed resources comply with predefined governance requirements.

These policies function as **preventive controls**, meaning they block non-compliant configurations before resources are deployed. By enforcing these policies at the resource group level, the project demonstrates how organizations can maintain security and compliance across cloud infrastructure.

The following governance policies were implemented within the environment.

## Policy 1 — Resource Tag Enforcement

A governance policy was implemented to require that all resources include the tag **Owner = SecurityTeam**. Resource tagging is an important governance practice that helps organizations maintain visibility and accountability over cloud assets.

In large cloud environments, resources may be created by multiple teams and administrators. Without standardized tagging, it becomes difficult to determine resource ownership, project association, and operational responsibility.

By enforcing mandatory tagging, the organization ensures that every deployed resource can be clearly associated with a responsible team. This supports asset inventory management, cost tracking, auditing processes, and security oversight.

This policy helps prevent unmanaged resources from appearing in the environment and strengthens governance accountability.



Home > Policy | Definitions > Require a tag and its value on resources

Assign policy ...

BasicsParametersRemediationManaged identityNon-compliance messagesReview + create

Basics

ScopeAzure subscription 1

Exclusions--

Policy definitionRequire a tag and its value on resources

Assignment nameRequire a tag and its value on resources

Version1.0\*

Description--

Policy enforcementDefault

Assigned byRezwan Mahmud

Advanced

Resource selectorsNo selectors associated with this assignment.

OverridesNo overrides associated with this assignment.

Parameters

Tag NameOwner

Tag ValueSecurityTeam

Remediation

Create a remediation taskNo

Managed identity

Create a Managed IdentityNo managed identity associated with this assignment.

PreviousNextCreate

SelectCancelClear All Selections

Give feedback

Scope

Subscription ⓘ

All selected

Resource Group

lawfirm-grc

Compliance Mapping:

| Framework      | Control                  | Description                                                                          |
|----------------|--------------------------|--------------------------------------------------------------------------------------|
| NIST SP 800-53 | CM-8                     | Resource tagging helps maintain inventory of cloud assets.                           |
| ISO 27001      | A.8                      | Asset management requires identification and ownership of resources.                 |
| SOC 2          | CC1                      | Governance controls enforce accountability for system resources.                     |
| PCI DSS        | Requirement 12           | Governance policies manage system security responsibilities.                         |
| PIPEDA         | Accountability Principle | Resource ownership tags establish responsibility for systems handling personal data. |

## Policy 2 — Disable Public Network Access for Storage

To protect sensitive legal documents stored within the Azure environment, a policy was implemented to prevent storage accounts from being accessible through public network connections.

Publicly accessible storage services represent a common cloud misconfiguration that can lead to accidental exposure of sensitive information. If public access is enabled, data stored within the storage account may become accessible from the internet.

By enforcing the disabling of public network access, the organization ensures that storage resources remain restricted to authorized internal access paths. This significantly reduces the risk of unauthorized data exposure and protects confidential client information stored in the legal document container.

This policy supports strong data protection practices by ensuring that storage resources cannot be unintentionally exposed to external networks.

Microsoft Azure Upgrade Search resources, services, and docs (G+)

Home > Policy | Definitions > Storage accounts should disable public network access

### Assign policy

Basics Parameters Remediation Managed identity **Non-compliance messages** Review + create

Non-compliance messages help users understand why a resource is not compliant with the policy. The message will be displayed when a resource is denied and in the evaluation details of any non-compliant resource.

Non-compliance message

Public network access must be disabled for storage accounts to protect sensitive data

#### Scope

Subscription All selected

Resource Group lawfirm-grc

Previous Next **Review + create** Select Cancel Clear All Selections [Give feedback](#)

### Compliance Mapping:

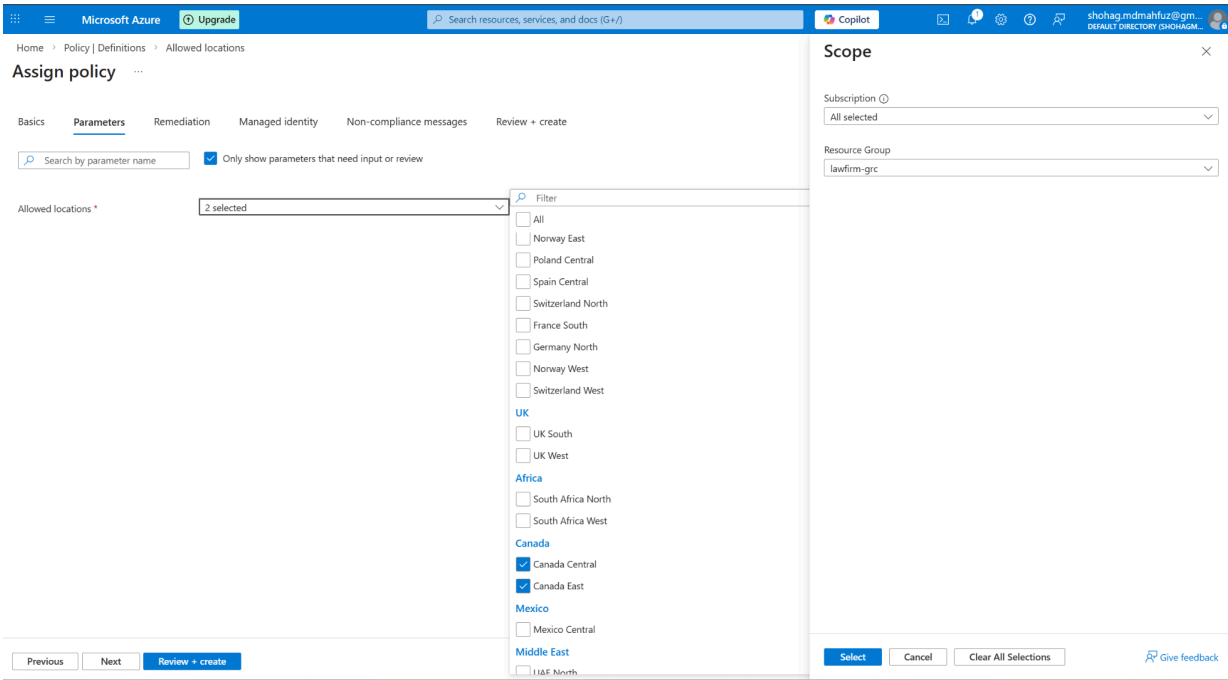
| Framework      | Control              | Description                                                   |
|----------------|----------------------|---------------------------------------------------------------|
| NIST SP 800-53 | AC-3                 | Prevents unauthorized access to storage resources.            |
| ISO 27001      | A.9                  | Access controls restrict exposure of sensitive data.          |
| SOC 2          | CC6                  | Logical access controls prevent unauthorized system access.   |
| PCI DSS        | Requirement 7        | Sensitive data access must be restricted to authorized users. |
| PIPEDA         | Safeguards Principle | Protects personal information from unauthorized exposure.     |

## Policy 3 — Restrict Deployment Locations

A governance policy was implemented to restrict resource deployment to the **Canada Central region**. This policy ensures that all cloud resources are deployed within an approved geographic location.

Location restrictions are commonly used to support **data residency and regulatory compliance requirements**. Many organizations must ensure that sensitive data is stored and processed within specific jurisdictions due to privacy laws and regulatory obligations.

By limiting deployments to a designated region, the organization maintains better control over where data is processed and stored. This helps ensure that the environment complies with regional regulatory requirements and internal governance standards.



**Compliance Mapping:**

| Framework      | Control                                     | Description                                                   |
|----------------|---------------------------------------------|---------------------------------------------------------------|
| NIST SP 800-53 | IA-5 / AC-6 (location restrictions context) | Controls help ensure systems operate within approved regions. |
| ISO 27001      | A.18                                        | Supports compliance with legal and regulatory obligations.    |
| SOC 2          | CC3                                         | Governance controls address regulatory risks.                 |
| PCI DSS        | Requirement 12                              | Organizations must maintain regulatory compliance practices.  |

|        |                          |                                                     |
|--------|--------------------------|-----------------------------------------------------|
| PIPEDA | Data Residency Principle | Ensures data remains within approved jurisdictions. |
|--------|--------------------------|-----------------------------------------------------|

## Policy 4 — Enforce Secure Transfer for Storage Accounts

A security policy was implemented to require that all communication with Azure storage accounts occurs using secure encrypted connections. This policy ensures that storage services only accept traffic over **HTTPS rather than unsecured HTTP connections**.

Unencrypted communication channels can expose sensitive data to interception during transmission. If HTTP connections are permitted, attackers may potentially capture sensitive information through network monitoring or man-in-the-middle attacks.

By enforcing secure transfer requirements, the environment ensures that all data transmitted between users, applications, and storage services is encrypted using modern TLS protocols. This protects sensitive legal documents from being exposed during network transmission.

Home > Policy | Definitions > Secure transfer to storage accounts should be enabled

Assign policy ...

Basics
Parameters
Remediation
Managed identity
Non-compliance messages
Review + create

Non-compliance messages help users understand why a resource is not compliant with the policy. The message will be displayed when a resource is denied and in the evaluation details of any non-compliant resource.

Non-compliance message

Secure transfer must be enabled. Configure the storage account to require HTTPS for all connections.

Scope

Subscription
All selected

Resource Group
lawfirm-grc

Previous
Next
Review + create

Select
Cancel
Clear All Selections
Give feedback

### Compliance Mapping:

| Framework      | Control              | Description                                                   |
|----------------|----------------------|---------------------------------------------------------------|
| NIST SP 800-53 | SC-8                 | Ensures confidentiality of data transmitted across networks.  |
| NIST SP 800-53 | SC-13                | Cryptographic protection for transmitted data.                |
| ISO 27001      | A.10                 | Cryptographic controls protect data during transmission.      |
| SOC 2          | CC6                  | Secure communication protects data exchanges between systems. |
| PCI DSS        | Requirement 4        | Sensitive data must be transmitted using encryption.          |
| PIPEDA         | Safeguards Principle | Encryption protects personal information during transmission. |

## Governance Impact

The implementation of these policies establishes a **centralized governance layer** within the cloud environment. These controls help prevent insecure configurations, enforce organizational security standards, and reduce the likelihood of human error during resource deployment.

Together, these policies strengthen the overall security posture of the environment by ensuring that:

- resources maintain proper ownership and accountability
- sensitive storage resources are protected from public exposure

- deployments follow geographic compliance requirements
- all storage communication is encrypted during transmission

These governance controls demonstrate how automated policy enforcement can support both **cloud security best practices and regulatory compliance requirements**.

## 12. Compliance Assessment

The implemented security controls were evaluated against several industry frameworks including:

NIST SP 800-53  
ISO 27001  
SOC 2  
PCI DSS  
PIPEDA

Control mapping demonstrates how cloud governance and security implementations support regulatory and security requirements.

**Compliance Mapping:**

| Security Domain   | Implemented Control                              | NIST SP 800-53 | ISO 27001 | SOC 2 | PCI DSS | PIPEDA         |
|-------------------|--------------------------------------------------|----------------|-----------|-------|---------|----------------|
| Governance        | Resource Group management and governance tagging | CM-8           | A.8       | CC 1  | Req 12  | Accountability |
| Identity Security | Entra ID users and security groups               | AC-2           | A.9       | CC 6  | Req 7   | Safeguards     |
| Access Control    | RBAC role assignments enforcing least privilege  | AC-3           | A.9       | CC 6  | Req 7   | Safeguards     |

|                                |                                                |             |      |      |        |                |
|--------------------------------|------------------------------------------------|-------------|------|------|--------|----------------|
| <b>Authentication</b>          | Multi-Factor Authentication (MFA)              | IA-2        | A.9  | CC 6 | Req 8  | Safeguards     |
| <b>Network Architecture</b>    | Virtual Network segmentation using subnets     | SC-7        | A.13 | CC 6 | Req 1  | Safeguards     |
| <b>Firewall Protection</b>     | Network Security Group (NSG) inbound filtering | SC-7        | A.13 | CC 6 | Req 1  | Safeguards     |
| <b>Infrastructure Security</b> | Secure VM deployment and minimal configuration | CM-6, CM-7  | A.12 | CC 6 | Req 2  | Safeguards     |
| <b>Data Protection</b>         | Azure Blob Storage encryption at rest          | SC-28       | A.10 | CC 6 | Req 3  | Safeguards     |
| <b>Access Restrictions</b>     | Private storage container configuration        | AC-3        | A.9  | CC 6 | Req 7  | Safeguards     |
| <b>Governance Enforcement</b>  | Azure Policy configuration enforcement         | CM-7        | A.12 | CC 1 | Req 12 | Accountability |
| <b>Secure Communication</b>    | HTTPS secure transfer enforcement              | SC-8, SC-13 | A.10 | CC 6 | Req 4  | Safeguards     |
| <b>Data Residency Control</b>  | Region restriction policy (Canada Central)     | AC-6        | A.18 | CC 3 | Req 12 | Data Residency |



# 13. Risk Assessment

A risk assessment was conducted to evaluate potential security threats to the simulated law firm cloud environment and determine how the implemented security controls mitigate these risks. Law firms handle sensitive legal documents and confidential client information, making strong governance and security controls critical for protecting data confidentiality, integrity, and availability.

The risk assessment focused on identifying common cloud security risks that could impact organizations operating in cloud environments, including unauthorized access, data exposure, insecure configurations, and network intrusion attempts. Each identified risk was evaluated based on its **likelihood of occurrence** and **potential impact** on the organization.

## Risk Rating Methodology

Risk levels were determined using a qualitative risk scoring model that evaluates both **Likelihood** and **Impact**.

- **Low Risk** – Minimal impact on business operations or data security
- **Medium Risk** – Moderate impact that may require additional mitigation controls
- **High Risk** – Significant impact that could compromise sensitive data or system availability

The implemented security controls were then evaluated to determine how effectively they reduce the identified risks.

## Risk Register

| Risk ID | Risk Description                          | Likelihood | Impact | Risk Level | Mitigation Control                                              | Residual Risk |
|---------|-------------------------------------------|------------|--------|------------|-----------------------------------------------------------------|---------------|
| R1      | Unauthorized access to cloud resources    | Medium     | High   | High       | Entra ID identity management, RBAC, Multi-Factor Authentication | Low           |
| R2      | Public exposure of sensitive storage data | Medium     | High   | High       | Private Blob Storage configuration and Azure Policy enforcement | Low           |

|    |                                                 |        |        |        |                                                                     |          |
|----|-------------------------------------------------|--------|--------|--------|---------------------------------------------------------------------|----------|
| R3 | Misconfigured cloud resources                   | Medium | Medium | Medium | Azure Policy governance controls preventing insecure configurations | Low      |
| R4 | Network intrusion attempts                      | Medium | High   | High   | Network Security Group firewall rules and subnet segmentation       | Low      |
| R5 | Data interception during transmission           | Low    | High   | Medium | HTTPS secure transfer enforcement and encryption protocols          | Low      |
| R6 | Deployment of resources outside approved region | Low    | Medium | Low    | Azure Policy region restriction policy                              | Very Low |

## Risk Assessment Outcome

The risk assessment demonstrates that the implemented security controls significantly reduce the likelihood and impact of common cloud security threats.

Key risk mitigation outcomes include:

- **Unauthorized access risks are reduced** through strong identity governance using Microsoft Entra ID, RBAC role assignments, and Multi-Factor Authentication.
- **Data exposure risks are mitigated** through private storage container access controls and encryption of sensitive data stored in Azure Blob Storage.
- **Network security risks are minimized** through virtual network segmentation and Network Security Group firewall rules restricting inbound traffic.
- **Configuration risks are reduced** through automated Azure Policy enforcement that prevents insecure resource deployments.
- **Compliance risks are addressed** through governance policies that enforce secure communication protocols and restrict resource deployment to approved geographic regions.

While no environment can eliminate all risks entirely, the implemented security architecture significantly reduces the overall attack surface and strengthens the organization's security posture.

The combination of **governance controls, identity security, network protection, encrypted storage, and policy enforcement** establishes a **defense-in-depth security model** that helps protect sensitive legal documents and client information while supporting regulatory compliance requirements.

## 14. Conclusion

This project demonstrates how cloud Governance, Risk, and Compliance (GRC) practices can be applied to a Microsoft Azure environment supporting a simulated small law firm. The implemented architecture incorporates multiple layers of security controls including identity governance, network segmentation, secure infrastructure deployment, encrypted data storage, and automated governance enforcement using Azure Policy.

The compliance assessment shows that the implemented controls align with major cybersecurity and regulatory frameworks including **NIST SP 800-53, ISO/IEC 27001, SOC 2, PCI DSS, and PIPEDA**. By mapping the deployed security mechanisms to these frameworks, the project demonstrates how cloud environments can be designed to support regulatory compliance while maintaining strong security governance.

The risk assessment further confirms that common cloud security risks such as **unauthorized access, data exposure, insecure configurations, and network intrusion attempts** are significantly reduced through the use of identity security, network controls, encryption, and automated governance policies.

Overall, the deployed architecture establishes a **defense-in-depth security model** that strengthens the organization's security posture while supporting governance, regulatory compliance, and risk management requirements. This project illustrates how organizations can securely deploy and manage cloud infrastructure while protecting sensitive legal documents and client information.